Emergency Training Simulator POC

Markdown documentation PDF copy

Client trust boundary

Source: docs/security/client-trust-boundary.md

Markdown stays editable. This PDF is the reading/share copy.

Boundary: this project is still a POC, not operational guidance.

Client trust boundary

The future Unreal client should be treated like a display and input device.

It should not be treated like the judge.

What the client may send

A client may send:

- start_session
- ordered trainee_action messages
- simple action payloads, if a future scenario needs them

What the client must not decide

A client must not decide:

- current scenario state
- whether an action is valid
- whether a warning or error should exist
- whether the scenario ended
- final outcome
- replay result
- review summary

Those belong to the backend.

Current backend checks

The backend checks:

- message shape
- unsupported extra fields
- safe ID characters
- safe scenario ID format
- safe action name format
- sequence number order
- duplicate event IDs
- active session count
- action count per session
- session/scenario consistency
- small JSON-shaped payloads

Why this matters

Later, Unreal may become visually impressive.

That does not mean it should become trusted.

If a future client can directly edit scenario state, then a bug or malicious client could fake a clean training result. So even in the POC, the contract is clear:

Unreal displays state. The backend owns state.